



Vulnerability Assessment &
Penetration Testing (VAPT) Report

NESS

04 October 2023



TABLE OF CONTENTS

1	EXECUTIVE SUMMARY	3
2	SCOPE OF TESTING	3
3	METHODOLOGIES USED	3
3.1	NMAP / ZENMAP.....	3
3.2	NESSUS	3
3.3	GREENBONE ENTERPRISE	4
4	STAY ONE STEP AHEAD OF ATTACKERS	4
4.1	OWASP.....	4
4.2	BRUTE FORCE.....	5
5	INFRASTRUCTURE.....	5
5.1	XNEELO SERVER – 129.232.196.24	5
5.2	INTERNAL OFFICE INFRASTRUCTURE – 10.0.0.0/24	7
6	RECOMMENDATIONS.....	7
7	REPORTING CONCLUSION	8
8	AUDITORS	8



1 EXECUTIVE SUMMARY

The purpose of this assessment was to point out security loopholes, business logic errors, and missing best security practices. The tests were carried out assuming the identity of an attacker or a malicious user but, no harm was made to the functionality or working of the application / network. A full scan was also performed on the infrastructure to demonstrate a known attack, i.e. someone on the internal network or same public subnetted infrastructure. The scans and brute force were performed over 7 (seven) business days, as full and slow comprehensive audits were performed. These types of scans also look at unknown connectivity options, including packet SYN requests.

The overall results will be published below, High-level, Sautech is comfortable and happy with the results. Some recommendations however, is offered and also mentioned throughout this document.

2 SCOPE OF TESTING

Security assessments include testing for security loopholes in the scope defined below. Apart from the following, no other information was provided. Nothing was assumed at the start of the security assessment. The following scope of servers were covered under the security audit:

- Server hosted at Xneelo – 129.232.196.24
- Internal Office Infrastructure – 10.0.0.0/24

3 METHODOLOGIES USED

Sautech performed various audit techniques that includes the following:

3.1 Nmap / Zenmap

Nmap, short for Network Mapper, is a free and open source tool used for vulnerability checking, port scanning and, of course, network mapping. Despite being created back in 1997, Nmap remains the gold standard against which all other similar tools either commercial or open source, are judged.

To deploy Nmap, users originally had to have some advanced programming skills, with the introduction of the Zenmap tool for Nmap, which adds a graphical interface that makes launching the program and analysing the returned output it generates much more accessible.

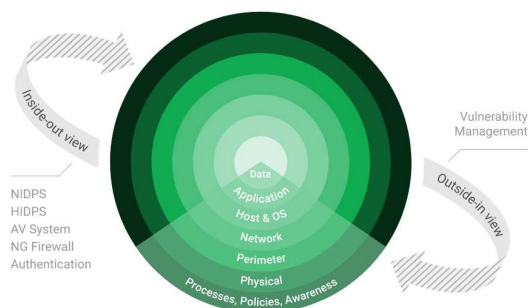
3.2 Nessus

Nessus is a remote security scanning tool, which scans a computer and raises an alert if it discovers any vulnerabilities that malicious hackers could use to gain access to any computer you have connected to a network. It does this by running over 1200 checks on a given computer, testing to see if any of these attacks could be used to break into the computer or otherwise harm it.



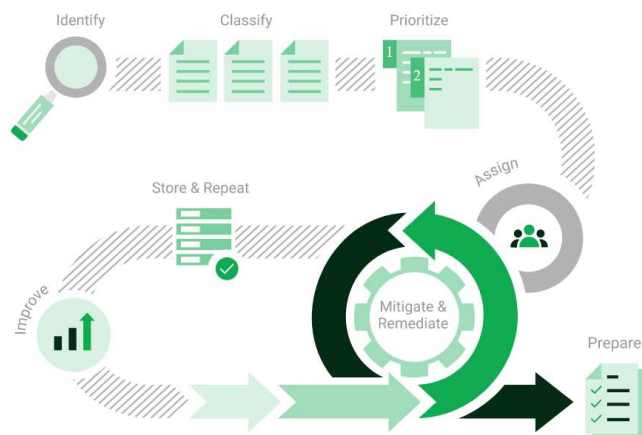
3.3 Greenbone Enterprise

Greenbone is the world's most widely used vulnerability management provider.



4 STAY ONE STEP AHEAD OF ATTACKERS

IT security is a process – Open Source vulnerability management provides the foundation. Once you know where the chinks are in your armor, you can do something about them.



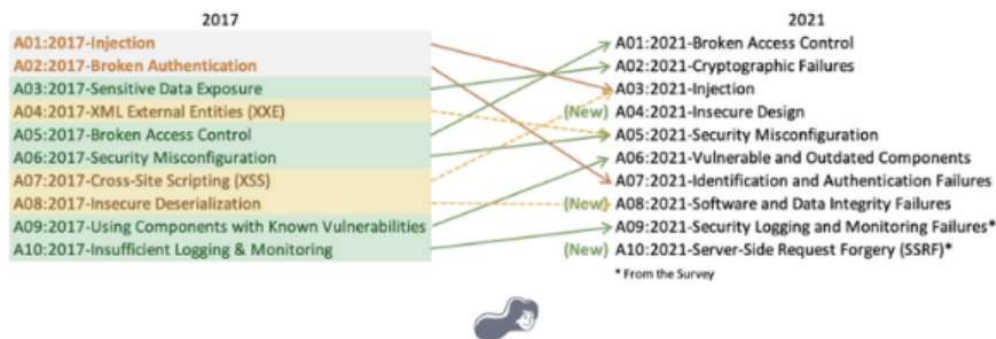
The process – from recognition to remedy and monitoring – represents a continuous cycle. You'll always be one step ahead of attackers.

4.1 OWASP

The Open Web Application Security Project (OWASP) is an online community that produces freely-available articles, methodologies, documentation, tools, and technologies in the field of web application security. The Open Web Application Security Project (OWASP) provides free and open resources. It is led by a non-profit called The OWASP Foundation. The OWASP Top 10 - 2021 is the published result of recent research based on comprehensive data compiled from over 40 partner organizations.



TOP 10:2021 Vulnerabilities



4.2 BRUTE FORCE

- A brute force attack is a hacking method that uses trial and error to crack passwords, login credentials, and encryption keys. It is a simple yet reliable tactic for gaining unauthorized access to individual accounts and organizations' systems and networks. The hacker tries multiple usernames and passwords, often using a computer to test a wide range of combinations, until they find the correct login information.
- The name "brute force" comes from attackers using excessively forceful attempts to gain access to user accounts. Despite being an old cyberattack method, brute force attacks are tried and tested and remain a popular tactic with hackers

5 INFRASTRUCTURE

5.1 Xneelo Server – 129.232.196.24

We have performed three types of scans / attacks on the production server namely:

- Vulnerability Assessments.

Vulnerability Assessment

Multiple technologies were used to perform a vulnerability assessment, below is the summarised version of the relevant results:

We have attached the below "highlight" in a separate report so that you can click on the "Plugin" link to get the resolution.



129.232.196.24



Vulnerabilities

Total: 30

SEVERITY	CVSS V3.0	PLUGIN	NAME
HIGH	7.5	42873	SSL Medium Strength Cipher Suites Supported (SWEET32)
MEDIUM	6.5	104743	TLS Version 1.0 Protocol Detection
MEDIUM	6.5	157288	TLS Version 1.1 Protocol Deprecated
INFO	N/A	10114	ICMP Timestamp Request Remote Date Disclosure
INFO	N/A	46180	Additional DNS Hostnames
INFO	N/A	45590	Common Platform Enumeration (CPE)
INFO	N/A	54615	Device Type
INFO	N/A	10092	FTP Server Detection
INFO	N/A	84502	HSTS Missing From HTTPS Server
INFO	N/A	84502	HSTS Missing From HTTPS Server
INFO	N/A	10107	HTTP Server Type and Version
INFO	N/A	24260	HyperText Transfer Protocol (HTTP) Information
INFO	N/A	11219	Nessus SYN scanner
INFO	N/A	19506	Nessus Scan Information
INFO	N/A	11936	OS Identification
INFO	N/A	10919	Open Port Re-check
INFO	N/A	50845	OpenSSL Detection
INFO	N/A	56984	SSL / TLS Versions Supported
INFO	N/A	10863	SSL Certificate Information
INFO	N/A	70544	SSL Cipher Block Chaining Cipher Suites Supported



INFO	N/A	21643	SSL Cipher Suites Supported
INFO	N/A	57041	SSL Perfect Forward Secrecy Cipher Suites Supported
INFO	N/A	94761	SSL Root Certification Authority Certificate Information
INFO	N/A	156899	SSL/TLS Recommended Cipher Suites
INFO	N/A	22964	Service Detection
INFO	N/A	25220	TCP/IP Timestamps Supported
INFO	N/A	84821	TLS ALPN Supported Protocol Enumeration
INFO	N/A	121010	TLS Version 1.1 Protocol Detection
INFO	N/A	136318	TLS Version 1.2 Protocol Detection
INFO	N/A	10287	Traceroute Information
INFO	N/A	10386	Web Server No 404 Error Code Check

* indicates the v3.0 score was not available; the v2.0 score is shown

5.2 Internal Office Infrastructure – 10.0.0.0/24

We have performed three types of scans/attacks on the production server namely:

- Vulnerability assessments

i) Vulnerability Assessment

Multiple technologies were used to perform a vulnerability assessment, below is the summarised version of the relevant results:

ii) Devices Detected on Local Network

We have attached a separate report hereto.

6 RECOMMENDATIONS

i) Ness Precision Server

SSL SWEET32 Ciphers to be updated to TLS 1.2/1.3 with TLS 1.0/1.1 disabled.

- Application / Website developers to confirm if TLS 1.2 supported.

ii) Ness Head Office

Current hardware do not have any security updates available. It is our recommendation that all discontinued hardware be replaced.



7 REPORTING CONCLUSION

Based on the OWASP reports it is best to attach these separate to the reporting document. These reports can then be shared with the relevant contractors and/or support personnel to implement the changes and updates.

The HTTPS updates as these are open to the public, low and medium risk, should be tested and implemented as soon as possible.

From a Hosted Infrastructure point of view, we are happy with the results.

Four addendum reports are attached to this report and should be read as one document.

With the following tests performed:

- Network scanning
- IDS/IPS disabled
- External HTTP and Port exploits
- Vulnerability assessment on CVE

8 AUDITORS

These audits were concluded over a period of 7 days.

We hereby confirm that the above information is true and correct:

04th October 2023 – Krugersdorp, South Africa

Riaan van Jaarsveld
Security Expert – CCSA

Lukas Janse van Rensburg
Security Engineer